



Security Incident Management



Document Owner:
IBEX IT Security

security@ibex.co

This document may not be duplicated, reproduced or distributed without the express written consent



Document Information

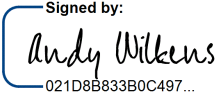
Document #:	IS -1.082
Document Title:	IS -1.082 Security Incident Management v2.3
Documentation Classification	INTERNAL (I)
Applicable Standard(s) / Framework(s):	PCI DSS / SOC 2/ ISO 27001
Document Status:	Final
Approved By:	Signed by:  021D8B833B0C497...
Date Approved:	1/16/2025
Date of Effectiveness	1/16/2025
Reference Document(s):	-

Table of Contents

1.	PURPOSE	1
2.	SCOPE.....	1
3.	ROLES AND RESPONSIBILITIES	1
4.	POLICY.....	2
4.1.	INFORMATION SECURITY INCIDENT IDENTIFICATION	2
4.1.1.	Reporting Security Weakness	2
4.1.2.	Reporting Security Malfunctions	2
4.1.3.	Reporting of Rogue Access Point	3
4.2.	INCIDENT MANAGEMENT PROCEDURES	3
4.2.1.	Security Incident Handling	3
4.2.2.	Incident Closure	5
4.3.	NOTIFICATION	6
4.4.	IR TRAINING, TESTING & AWARENESS	1
5.	ENFORCEMENT	1
6.	DEFINITIONS AND ABBREVIATIONS	1
7.	REVISION HISTORY	2

1. Purpose

This policy serves the purpose of handling security incidents effectively to minimize the damage that may arise as a result of such incidents and malfunctions, in addition to monitor and proactively detect security deviations.

2. Scope

This policy applies on all IBEX employees responsible for identification of any potential security weaknesses, incident, abnormal behavior or vulnerability and timely reporting to concerned teams.

3. Roles and Responsibilities

Role	Description/Responsibility
CERT POCs	Personnel from supporting functions which are designated part of CERT group and are tasked with providing necessary support, in executing Incident Response Plan, to IT Security team for conducting security incident investigation(s). These include but are not limited to - GSO - GNOC - Field Support etc.
Vigilance/ MDR Team	Third party service ensuring 24x7 Monitoring of IBEX environment to identify IOC and make escalations to IBEX IT Security team where necessary. Aiding in forensic investigation in case of a security breach.
Cyber Committee	Comprising of Senior IT Leadership, Finance Controller, Legal Counsel and some members of ELT to determine incident materiality and reporting obligations
Executive Leadership Team (ELT)	C-Suite executives, shall authorize external communication, notification and further course of action on executing corrective and preventive actions.
All employees	Identification and timely reporting of any malicious/suspicious activity or events.
Service Desk	Initiate email or ticket based on the incident scenario and involve relevant POC's for investigations.
Incident Commander	Responsible for orchestrating an effective and efficient response to incidents, whilst ensuring efficacious resources utilization, risk mitigation, and accomplish objectives. Incident Commander shall be designated from IT Security Team.
Incident Management Team	Document all the production impacting incident details including impact, containment and RCA in coordination with relevant teams.
Human Resources	Any policy violation is referred to HR for disciplinary action or serving a notice to the affected employee(s) causing security incident due to policy violation.

4. Policy

4.1. Information Security Incident Identification

All suspected security incidents shall be reported to the IT Security (security@ibex.co)/ IT Service desk (servicedesk@ibex.co) / Incident Management (incident.management@ibex.co) by sending an email on their respective email addresses. The IT ServiceDesk / Incident Management shall inform the IT Security team about all security-related incidents reported. Incidents may be technical or operational in nature.

A security incident shall be defined as any malicious or suspicious threat event which adversely impacts IBEX's business operations, revenue, reputation, goodwill, investor confidence or exposes IBEX to compliance, contractual and/or legal violations. Based on above definition, IT Security Team shall determine whether an event classifies as security incident. Such events may include but not limited to the following:

- I. Malware and Ransomware Infection or Outbreak
- II. Unauthorized access to network or information systems
- III. Unauthorized access or disclosure of non-public data
- IV. Unauthorized data modification or deletion
- V. Denial of Service (DOS) Or Distributed Denial of Service (DDOS) Attacks
- VI. Abuse of information systems or violation of IBEX Information Security Policies
- VII. Potentially suspicious emails from unknown sources
- VIII. Malicious/Suspicious emails from employees
- IX. Disclosure of confidential information
- X. Disclosure of private information
- XI. Rogue Access Point Detection
- XII. Detection of stored PAN anywhere it is not expected

4.1.1. Reporting Security Weakness

Suspected security weaknesses resulting from failure of existing security control shall also be reported in addition to actual failures. These shall be reported without any undue delay. Users shall not, however, attempt to prove/exploit any security weakness. Examples of such weaknesses include:

- a) Security weakness in a particular software/hardware being used at IBEX
- b) Network Security weakness
- c) Security weakness in a practice/procedure/standard
- d) Physical Security weakness

4.1.2. Reporting Security Malfunctions

Day-to-day software malfunctions and/or vulnerabilities shall be reported to ITFS and Service Desk

4.1.3. Reporting of Rogue Access Point

Detection of rogue access points, AP not present in approved list of Wireless Access Points, shall be reported to IT Security team and Local Field Support.

4.2. Incident Management Procedures

The closure of suspected security incidents will follow the steps mentioned in Incident Handling below section.

4.2.1. Security Incident Handling

The following steps shall be performed while incident handling:

I. Preparation:

1. IT Security POC shall follow the established policies, procedures defined for the incident response and communicate with appropriate stakeholder on defined channels i.e. Incident bridge, CERT email or IM group; and email solution for escalations etc.
2. IT Security POC shall either initiate the incident investigation bridge or contact IBEX Incident Management function or IBEX ServiceDesk to do so and request required CERT POCs to join the bridge

II. Identification:

1. A trained nominated IT Security member shall collect artefacts and evidences of malicious event from all relevant monitoring solutions in coordination with Vigilance team, i.e. log alerts from SIEM, EDR, IDS/IPS, firewalls, email security gateways, and may request logs from CERT POCs in order to determine whether or not that particular malicious event has resulted in a security incident that includes but not limited to incidents listed down in section 4.1.
2. Post conclusion, identified incident shall be documented, required evidences shall be gathered and communicated on need to know basis.
3. In event of detection of stored PAN or account data (reference to PCI DSS) where it is not expected to, investigation will be performed whether Sensitive Authentication Data (SAD) is also being stored with it.

III. Containment:

1. Once the threat has been identified, IT Security team in coordination with CERT POCs shall ascertain the extent of breach and determine the level of spread within the IBEX infrastructure .
2. Once stored PAN or account data is identified at unexpected locations,
 - a. Determine where the account data came from and how it ended up where it was not expected.
 - b. if PAN is discovered outside the CDE, its retrieval, secure deletion and/or migration into the CDE shall be ensured
3. Designated Incident Commander(s) will coordinate with relevant teams to block identified threat actors, and if necessary, the Indicators of Compromise (IOCs).
4. To prevent further damage to other systems/networks and the organization at large, necessary measures, such as involving Vigilance team for investigations, to contain the threat shall be assured.

Note: Identification and containment steps shall run simultaneously throughout the process till the time a reasonable assurance is obtained that the incident could not have been spread further and has been fully contained

IV. Eradication:

IT Security team in coordination with CERT members will determine the root cause upon incident containment, and consequently work to take necessary corrective actions to address the issue. This may include but not be limited to

1. installing patches to fix the vulnerability
2. restore a failed security control
3. restoring affected servers from backup
4. remove malicious artefacts
5. change compromised user's passwords etc.
6. remediating data leaks or process gaps that resulted in account data being stored unexpectedly.

In general, all the entry point(s) that the threat actor used to gain access to the network/system will be eliminated and necessary actions shall be ensured to remediate identified gaps.

V. Recovery:

Data recovery or restoration processes will be initiated, once the threat has been eradicated, against affected production system to reconstitute. This may include

1. restoring data from backups
2. opening blocked network communication in a restricting manner
3. re-instating affected user accounts and their access to production etc.

Upon implementation of the corrective actions, IT Security shall thoroughly review to validate the efficacy of implemented corrective actions and verify its working as intended.

This can be done through applicable methods including but not limited to

1. vulnerability scans
2. anti-malware scans
3. penetration testing
4. reviewing logs from SIEM and other security tools

VI. Review:

As a final step the IT security team shall conclude the incident investigation and based upon the root cause, preventive actions shall be suggested to ensure similar incidents do not occur in future.

4.2.2. Incident Closure

Vigilance/MDR or IT Security team shall capture the details of incident and suitable modifications shall be made to the Information Security policies and controls, if necessary. IT Security team shall log all security incidents. Once verified, if any employee found to be involved in violation of IBEX policies which may result in a security incident or breach shall be referred to HR for disciplinary action.

Depending upon the nature of these incidents, the IT Security POC may decide whether these incidents can be used in user-awareness training, as examples of what would happen, how to respond to such incidents and how to avoid them in future.

All information about the security incident, data collected during the investigation and findings will be shared only on need-to-know basis with internal/external parties.

4.3. Notification

All incident escalations and notifications shall continue during the investigation process. Based upon identification of incident and its spread within the organization, relevant escalations and notifications shall be rolled out as the investigation progresses. Based upon the spread of incident, its impact and implication on IBEX's production, financial impact and goodwill and in accordance with regulatory, contractual and compliance requirements, escalations and notifications shall be rolled out, in lieu with the below Escalation Matrix.

Sr. No	Impact Category	Category Severity Levels	Escalation to*	Notification to Outside Parties
1	Functional Impact – A measure of the impact to business functionality or ability to provide services	MINIMAL IMPACT TO NON-CRITICAL SERVICES – Some small level of impact causing low or moderate service degradation to non-critical systems and services which do not have direct impact on ibex operations reputation, contractual, compliance and legal obligations but prolonged persistence can start to have an impact such as security logging services, standby secondary setups, backup services etc	Concerned IT Dept. Heads / Senior Vice President of IT	No
2		MINIMAL IMPACT TO CRITICAL SERVICES –Minimal causing low or moderate service degradation but to a critical system or service having direct impact on ibex operations reputation, contractual, compliance and legal obligations, such as email, active directory, financial reporting, network services, voice services etc	Chief Technology Officer (CTO) / Cyber Committee	Per discretion of Cyber Committee
3		SIGNIFICANT IMPACT TO NON-CRITICAL SERVICES – A non-critical service or system has a significant impact causing high or critical service degradation or partial denial of service		Per discretion of Cyber Committee
4		DENIAL OF NON-CRITICAL SERVICES – A non-critical system is denied or destroyed and access to service or system is completely unavailable		Per discretion of Cyber Committee
5		SIGNIFICANT IMPACT TO CRITICAL SERVICES – A critical system has a significant impact causing high or critical service degradation or partial denial of service, such as deletion of multiple Active Directory user accounts etc.	Executive Leadership (ELT)	Per discretion of ELT/Legal Counsel
6		DENIAL OF CRITICAL SERVICES/LOSS OF CONTROL – A critical system has been rendered unavailable causing complete denial of service such as unable to gain privileged access to active directory servers or network equipment.	Executive Leadership (ELT)	Per discretion of ELT/Legal Counsel

Sr. No	Impact Category	Category Severity Levels	Escalation to*	Notification to Outside Parties
1	Information Impact – Describes the type of information lost, compromised, or corrupted.	SUSPECTED BUT NOT IDENTIFIED – A data loss or impact to availability is suspected, but no direct confirmation exists.	SVP IT/ Concerned IT dept. Head(s)	-
2		DESTRUCTION OF NON-CRITICAL SYSTEMS – Destructive techniques, such as master boot record (MBR) overwrite against a non-critical system.		-
3		CRITICAL SYSTEMS DATA BREACH - Data pertaining to a critical system has been exfiltrated.	Chief Technology Officer (CTO) / Cyber Committee / Executive Leadership (ELT)	Per discretion of Cyber Committee
4		CORE CREDENTIAL COMPROMISE – Core system credentials (such as domain or enterprise administrative credentials) or credentials for critical systems have been exfiltrated.		Per discretion of Cyber Committee
5		DESTRUCTION OF CRITICAL SYSTEM – Destructive techniques, such as MBR overwrite; have been used against a critical system.	Executive Leadership (ELT)	Per discretion of Cyber Committee
6		PRIVACY/CLIENT DATA BREACH – The confidentiality of personally identifiable information (PII) or personal health information (PHI) or Payment Card Information (PCI) or client sensitive data was compromised.	Executive Leadership (ELT)	Yes
7		PROPRIETARY INFORMATION BREACH – The confidentiality of unclassified proprietary information, such as protected critical infrastructure information (PCII), intellectual property, or trade secrets was compromised.	Executive Leadership (ELT)	Yes
1	Recoverability – Identifies the scope of resources needed to recover from the incident	REGULAR – Time to recovery is predictable with existing resources.	VP IT Security/ SVP IT/ Chief Technology Officer (CTO)	-
2		SUPPLEMENTED – Time to recovery is predictable with additional resources.	Cyber Committee	Per discretion of Cyber Committee
3		EXTENDED – Time to recovery is unpredictable; additional resources and outside help are needed.	Executive Leadership (ELT)	Yes
4		NOT RECOVERABLE – Recovery from the incident is not possible (e.g., sensitive data exfiltrated and posted publicly).	Executive Leadership (ELT)	Yes

Note: “Escalation to” column specifies that the sequence of escalation in relation to the severity levels.*

NOTIFICATION TO OUTSIDE PARTIES includes but is not limited to IBEX clients, law enforcement agencies, PCI DSS Payment Brands or any other third parties that are required to be notified as part of IBEX’s legal, regulatory, contractual and compliance requirements and these requirements shall govern the timing of the notification to be rolled out. Such communication shall be handled by Compliance, Legal and Client Services Team.

4.4. IR Training, Testing & Awareness

Incident response training material and guidance shall be provided to CERT members and end users through security trainings, awareness advisories, meetings or other suitable channels.

Incident response exercise may be conducted at least once a year to test the incident scenario and results to be documented for any needed improvements in incident response procedure.

5. Enforcement

Any employee found to have violated this policy shall be subject to disciplinary action. Moreover, any violations shall be logged and investigated for root cause analysis and appropriate action shall be taken as per IBEX policies.

6. Definitions and Abbreviations

Definition & Abb.	Description
C&C	Command & Control Server communicating and controlling the malware.
SIEM	Security Information and Event Management
EDR	Endpoint Detection and Response Solution
IOC	Indicators of Compromise
ELT	Executive Leadership Team
MDR	Managed Detection and Response Service provided by EDR service provider for responding on EDR Alerts.
POC	Point of Contact
IDS	Intrusion Detection System
CERT	Computer Emergency Response Team
AP	Access Point
IR	Incident Response
RCA	Root cause analysis
PAN	Primary Account Data as defined in PCI DSS v4.0.1
SAD	Sensitive Authentication Data as defined in PCI DSS v4.0.1
Account Data	Consists of Cardholder Data (CHD) and SAD as defined in PCI DSS v4.0.1
CDE	Cardholder Data Environment as defined in PCI DSS v4.0.1

7. Revision History

Version	Date	Details of Changes	Change By	Reviewed By	Approved By
1	1/1/2016	Initial Draft		Atif Naseem	Waseem Ahmad
1.1	6/2/2017	Minor changes – added Legal in Severity 1 Escalation		Muqet Kamal	
1.2	5/16/2018	Minor changes		Muqet Kamal	
1.3	6/28/2018	Added rogue access point detection		Muqet Kamal	Mubsshar Ismail
1.4	7/2/2019	Minor Changes		Muqet Kamal	Mubsshar Ismail
1.5	1/21/2021	Added Ransomware Guidance and other minor changes		Muqet Kamal	Mubsshar Ismail
2.0	1/14/2022	Modified Escalation timelines, Incident Response Handling	Muqet Kamal	Mubsshar Ismail	Jim Ferrato
2.1	3/14/2023	Modifications made to Incident response handling and POC's with IR training section as an addition	Arslan Tariq/ Sidra Maryam	Faisal Awan/ Mubsshar Ismail	Jim Ferrato
2.2	3/12/2024	Minor revision with addition of incident commander role and responsibility and addition of the same in section 4.2.1 – II. Containment	Asim Naeem/ Sidra Maryam	Muqet Kamal Faisal Awan Mubsshar Ismail	Jim Ferrato
2.3	1/7/2025	PCI v4.0 requirements, incident definition and notification clauses modified	Sidra Maryam Muqet Kamal	Mubsshar Ismail Sandra Fernandez Amy vanDerSchouw Jason Malmberg	Andreas Wilkens